

Seguridad en la Nube

Responsabilidad compartida, IAM, redes virtuales, secretos y los errores que dominan los breaches en AWS, Azure y GCP.

0x0A · CLD



shared
responsibility

• 16 diapositivas

~22 min

Nivel · Iniciación + Práctica

Qué vamos a ver

/01	Modelos · IaaS, PaaS, SaaS	qué hay debajo
/02	Responsabilidad compartida	qué te toca
/03	IAM · identidad y permisos	el control n°1
/04	Red · VPC, SG, NACL	segmentación
/05	Almacenamiento · S3 y similares	data exposure
/06	Secretos · KMS, Vault	no en git
/07	Logging y detección	CloudTrail · GuardDuty
/08	IaC · Terraform y SAST	DevSecOps
/09	Contenedores y Kubernetes	capa moderna
/10	Top 5 misconfigs	errores reales
/11	Lab · auditoría IaC	manos a la obra

03 · QUÉ TE ENTREGA CADA MODELO

IaaS · PaaS · SaaS

// IAAS

Infraestructura

Máquinas, redes y almacenamiento como servicio. Tú instalas el SO, las apps y los parches.

eg. EC2, Azure VM, GCE

// PAAS

Plataforma

El proveedor te da runtime, BD gestionada y orquestación. Tú gestionas el código y la configuración.

eg. App Engine, RDS, Lambda

// SAAS

Software

Aplicación lista para usar. Sólo gestionas usuarios, datos y configuración de acceso.

eg. Microsoft 365, Salesforce

▲ Cuanto más arriba en la pila (SaaS), más delegas. Pero **tus datos y tus identidades siempre son tuyos.**

Modelo de responsabilidad compartida

Proveedor // security OF the cloud		Cliente · tú // security IN the cloud	
datacenter	Seguridad física, energía, refrigeración.	datos	Clasificación, cifrado, retención, borrado.
hardware	Servidores, red física, hipervisores.	identidad	Usuarios, roles, MFA, federación.
plataforma	Software de orquestación, APIs internas.	red	VPC, subnets, Security Groups, WAF.
cumplimiento	ISO 27001, SOC 2, PCI-DSS del propio servicio.	apps + OS	En IaaS también el SO. Patches, runtime, código.

IAM · identidad y permisos

[01]MFA siempre · empezando por la cuenta root/owner. Llaves FID02 > TOTP > SMS.	mfa
[02]Mínimo privilegio · permisos sólo a lo necesario. Revisar con IAM Access Analyzer o equivalentes.	least
[03]Roles, no usuarios · servicios asumen roles · evita claves de acceso a largo plazo.	role
[04]Federación con tu IdP · SSO con Okta, Entra ID, Google Workspace. Una identidad por persona.	ssso
[05]Cuentas separadas por entorno · prod / staging / dev como cuentas independientes (AWS Organizations, GCP Folders).	org
[06]Cero claves en código · usar metadata IAM, Workload Identity, OIDC desde CI/CD.	keys
[07]Revisión periódica · usuarios inactivos, permisos no usados, accesos cruzados (CSPM).	review

VPC, subnets y firewalls

VPC

Red virtual aislada. Define rangos privados, subnets públicas y privadas, route tables. Tu "datacenter virtual".

Security Group

Firewall stateful por instancia. Lista de allow inbound/outbound por puerto. *Default: nada abierto.*

NACL

ACL a nivel de subnet. Stateless • útil para defensas de capa adicional o blanqueo de IPs.

PrivateLink / VPC endpoint

Acceso a servicios sin pasar por Internet. S3, KMS y otros desde tu VPC privada.

WAF

Filtro L7 ante app pública. Bloquea OWASP Top 10 y rate-limit en el edge.

Shield • DDoS

Mitigación de DDoS a escala del proveedor. Cloudflare, AWS Shield, Azure DDoS Protection.

Almacenamiento de objetos

[01]Block Public Access activo a nivel de cuenta y bucket. Sin excepciones salvo CDN explícita.	public
[02]Cifrado en reposo con KMS · SSE-KMS en S3 · CMK propias para datos regulados.	enc
[03]Cifrado en tránsito · TLS forzado vía bucket policy (aws:SecureTransport).	tls
[04]Versionado + Object Lock · protege contra borrado accidental y ransomware.	backup
[05]Pre-signed URLs con expiración corta para compartir, no permisos públicos.	share
[06]Logging de acceso · S3 Server Access Logs / CloudTrail data events.	audit
[07]Clasificación de datos · Macie / Purview escanean PII automáticamente.	dlp

Gestión de secretos y KMS

KMS

// key mgmt service

Servicio gestionado de claves (AWS KMS, Azure Key Vault, GCP KMS). Cifrado por sobre, rotación automática, auditoría.

Secrets Manager

// secret store

Para credenciales rotables: BD, API keys. AWS Secrets Manager, Azure Key Vault, GCP Secret Manager.

HashiCorp Vault // open-source

Multi-cloud. Dynamic secrets, leases cortos, integración con K8s y CI/CD.

SOPS / age

// IaC

Cifrado de fichero a fichero · ideal para secrets en repos GitOps · respaldado por KMS.

OIDC en CI/CD // keyless

GitHub Actions / GitLab → cloud sin claves estáticas. Federación efímera con tokens OIDC.

gitleaks // scanners

/ Detección de secretos commiteados accidentalmente · pre-commit + CI.

Logging y detección

Trazas

// "qué pasó"

AWS	CloudTrail (API) + VPC Flow Logs (red) + S3 Access Logs.
Azure	Activity Log + NSG Flow Logs + Storage logging.
GCP	Cloud Audit Logs + VPC Flow Logs.
destino	Cuenta de logs separada · retención larga · inmutable.

Detección

// "esto es raro"

AWS	GuardDuty (ML sobre logs) + Security Hub (CSPM).
Azure	Defender for Cloud + Sentinel (SIEM SaaS).
GCP	Security Command Center · postura + detección.
terceros	Wiz · Prisma Cloud · Lacework · Datadog Cloud SIEM.

IaC + DevSecOps

[01]Todo por IaC · Terraform, OpenTofu, Pulumi, CloudFormation. Cambios revisables.	iac
[02]Análisis estático · tfsec, checkov, kics, terrascan en pre-commit y CI.	sast
[03]Plan + revisión obligatoria · nadie aplica directo a prod. terraform plan en PR.	pr
[04]OPA / Conftest · políticas como código · "no se pueden crear SGs 0.0.0.0/0".	policy
[05]Estado remoto y cifrado · backend S3+KMS con state lock (DynamoDB).	state
[06]Drift detection · alertar cuando lo desplegado no coincide con el código.	drift

Contenedores y Kubernetes

[01]Imágenes minimal · distroless / alpine · menos software, menos CVEs.	image
[02]Escaneo de imágenes · Trivy, Grype, Snyk · bloquea push si crítico.	scan
[03]Firma de imágenes · cosign + sigstore · admission controller verifica firma.	sign
[04]No root en contenedor · runAsNonRoot, readOnlyRootFilesystem, capabilities reducidas.	user
[05]NetworkPolicy · default-deny entre namespaces. Sin esto, todo se ve con todo.	net
[06]RBAC y ServiceAccounts dedicadas · IRSA / Workload Identity para acceso al cloud.	rbac
[07]Admission policy · Kyverno, OPA Gatekeeper para forzar las reglas anteriores.	policy

Top 5 misconfiguraciones

Bucket público

S3/Blob/GCS abierto a Internet o con ACLs laxas. Causa habitual de leaks masivos de PII y backups.

fix · Block Public Access + alertas

SG 0.0.0.0/0 en SSH/RDP

Puerto 22 o 3389 expuesto al mundo. Brute-force constante, secuestro de cuentas.

fix · bastion + sólo IPs corporativas

Cuentas con permisos *

Usuarios con Action: *. "admin everywhere". Una credencial filtrada = todo el entorno.

fix · least privilege + roles

Credenciales en repo

AWS keys, tokens, contraseñas commiteadas. Bots las indexan en minutos.

fix · scanners + OIDC keyless

Sin MFA en root

Cuenta raíz con sólo contraseña. Phishing exitoso = pérdida total del entorno.

fix · FIDO2 hardware key + alarmas

Sin logging

CloudTrail / Activity Log desactivado o sin destino seguro. Sin trazas, no hay investigación posible.

fix · habilitar + cuenta de log aparte

Genera un Terraform vulnerable

```
// auditor  
Kali Linux  
172.X.X.X ·  
sin red
```

~/lab-
10/cloud.tf

```
// output  
cloud.tf  
25 líneas
```

CUATRO FALLOS A PROPÓSITO

- › **S3 público** en el bucket.
- › **SG** con 0.0.0.0/0 en 22.
- › **IAM** con Action: "*".
- › **Credenciales** en claro.

```
●●● kali@kali · ~ · bash
```

[01] Crea el directorio del lab:

```
$ mkdir -p ~/lab-10 && cd ~/lab-10
```

[02] Genera el fichero Terraform con fallos (here doc):

```
$ cat > cloud.tf << 'EOF'
```

```
resource "aws_s3_bucket" "d" { bucket="co-data" ; acl="public-  
read" }
```

```
resource "aws_security_group" "w" {  
  ingress { from_port=22 ; to_port=22 ; protocol="tcp" ;  
    cidr_blocks=["0.0.0.0/0"] }  
}
```

```
resource "aws_iam_policy" "a" {  
  policy = jsonencode({Statement=  
    [{Effect="Allow",Action="*",Resource="*"}]})  
}
```

```
provider "aws" {  
  access_key="AKIAIOSFODNN7EXAMPLE"  
  secret_key="wJalrXUtnFEMI/K7MDENG/bPxrFiCYEXAMPLEKEY"  
}  
EOF
```


Encuentra los 4 fallos

QUÉ BUSCAR Y POR QUÉ

- › **S3 público** · expone datos sin autenticación.
- › **SG 0.0.0.0/0:22** · SSH al mundo, brute-force constante.
- › **IAM "*"** · una credencial filtrada = todo el entorno.
- › **Claves en claro** · cualquier commit las publica para siempre.
- › Mapea cada hallazgo a su control **CIS AWS**.

●●● kali@kali · ~/lab-10 · bash

[03] Bucket S3 público:

```
$ grep -nE 'acl.*public' cloud.tf
```

public-read → cualquiera en internet puede leer los archivos del bucket

[04] Security Group abierto a Internet:

```
$ grep -nE '0\.0\.0\.0/0' cloud.tf
```

0.0.0.0/0 → el puerto 22 (SSH) abierto a todo internet; cualquiera puede conectarse

[05] Policy IAM con wildcard total:

```
$ grep -nE 'Action[^A-Za-z]+\*' cloud.tf
```

Action="*" → esa cuenta puede hacer cualquier cosa en AWS · el error más grave

[06] Credenciales hardcoded:

```
$ grep -niE 'access_key|secret_key|password' cloud.tf
```

claves en el código → quien acceda al repo tiene acceso total a la cuenta AWS

6 ideas para llevarte

- /01 El cloud es **responsabilidad compartida**. El proveedor protege la nube · tú proteges *en* la nube.
- /02 **IAM es el control nº1**. Sin MFA y mínimo privilegio, todo lo demás se cae.
- /03 Datos · cifrado en reposo y en tránsito + **Block Public Access** por defecto.
- /04 Secretos en **KMS o Vault**, nunca en código. Federación OIDC en CI/CD.
- /05 Todo por **laC con análisis estático** (tfsec, checkov) y políticas (OPA).
- /06 Visibilidad · **CloudTrail/Activity Log + CSPM + GuardDuty**. Sin trazas, sin investigación.

SIGUIENTE · TEMA 11

Respuesta ante Incidentes

El ciclo NIST de respuesta, fases (preparación, detección, contención, erradicación, recuperación), DFIR, playbooks y comunicaciones.

→ continúa en el siguiente vídeo

Para profundizar

Documentación oficial de los proveedores + benchmarks abiertos.

[1]	NIST	SP 800-145 (definición de cloud) · 800-190 (containers) · 800-207 (Zero Trust) · 800-218 (SSDF)
[2]	CIS	CIS AWS / Azure / GCP / Kubernetes Foundations Benchmarks · cisecurity.org
[3]	CSA	Cloud Security Alliance · CCM v4 · Top Threats to Cloud Computing · cloudsecurityalliance.org
[4]	Proveedores	AWS Well-Architected – Security Pillar · Microsoft Cloud Security · Google Cloud Security Foundations
[5]	MITRE	ATT&CK for Cloud (IaaS, Azure AD, Office 365) · attack.mitre.org
[6]	CCN-CERT / INCIBE	CCN-STIC-823 Servicios Cloud · ccn-cert.cni.es · incibe.es